

NORMA
BRASILEIRA

ABNT NBR
ISO/IEC
38500

Segunda edição
28.11.2018

Tecnologia da informação — Governança da TI para a organização

Information technology — Governance of IT for the organization



ICS 35.020

ISBN 978-85-07-07805-0



ASSOCIAÇÃO
BRASILEIRA
DE NORMAS
TÉCNICAS

Número de referência
ABNT NBR ISO/IEC 38500:2018
13 páginas

© ISO/IEC 2015 - © ABNT 2018

ABNT NBR ISO/IEC 38500:2018



© ISO/IEC 2015

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT, único representante da IEC no território brasileiro.

© ABNT 2018

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT.

ABNT

Av. Treze de Maio, 13 - 28º andar
20031-901 - Rio de Janeiro - RJ
Tel.: + 55 21 3974-2300
Fax: + 55 21 3974-2346
abnt@abnt.org.br
www.abnt.org.br

Sumário

Página

Prefácio Nacional	iv
Introdução	vi
1 Escopo	1
2 Termos e definições	1
3 Benefícios da boa governança da TI	5
4 Princípios e modelo para uma boa governança da TI	6
4.1 Princípios	6
4.2 Modelo	7
5 Orientação para a Governança da TI	8
5.1 Geral	8
5.2 Princípio 1: Responsabilidade	9
5.3 Princípio 2: Estratégia	9
5.4 Princípio 3: Aquisição	10
5.5 Princípio 4: Desempenho	10
5.6 Princípio 5: Conformidade	11
5.7 Princípio 6: Comportamento Humano	12
Bibliografia	13
 Figura	
Figura 1 – Modelo para a Governança da TI	7

ABNT NBR ISO/IEC 38500:2018

Prefácio Nacional

A Associação Brasileira de Normas Técnicas (ABNT) é o Foro Nacional de Normalização. As Normas Brasileiras, cujo conteúdo é de responsabilidade dos Comitês Brasileiros (ABNT/CB), dos Organismos de Normalização Setorial (ABNT/ONS) e das Comissões de Estudo Especiais (ABNT/CEE), são elaboradas por Comissões de Estudo (CE), formadas pelas partes interessadas no tema objeto da normalização.

Os Documentos Técnicos Internacionais são adotados conforme as regras da ABNT Diretiva 3.

A ABNT chama a atenção para que, apesar de ter sido solicitada manifestação sobre eventuais direitos de patentes durante a Consulta Nacional, estes podem ocorrer e devem ser comunicados à ABNT a qualquer momento (Lei nº 9.279, de 14 de maio de 1996).

Ressalta-se que Normas Brasileiras podem ser objeto de citação em Regulamentos Técnicos. Nestes casos, os órgãos responsáveis pelos Regulamentos Técnicos podem determinar outras datas para exigência dos requisitos desta Norma.

A ABNT NBR ISO/IEC 38500 foi elaborada no Comitê Brasileiro de Computadores e Processamento de Dados (ABNT/CB-021), pela Comissão de Estudo de Engenharia de Software e Sistemas (CE-021:000.007). O Projeto circulou em Consulta Nacional conforme Edital nº 10, de 22.10.2018 a 20.11.2018.

Esta segunda edição cancela e substitui a edição anterior (ABNT NBR ISO/IEC 38500:2009), a qual foi tecnicamente revisada.

Esta Norma é uma adoção idêntica, em conteúdo técnico, estrutura e redação, à ISO/IEC 38500:2009, que foi elaborada pelo *TJoint Technical Committee Information Technology* (ISO/IEC JTC1), *Subcommittee IT Service Management and IT Governance* (SC 40), conforme ISO/IEC Guide 21-1:2005.

O Escopo desta Norma Brasileira em inglês é o seguinte:

Scope

This Standard provides guiding principles for members of governing bodies of organizations (which can comprise owners, directors, partners, executive managers, or similar) on the effective, efficient, and acceptable use of information technology (IT) within their organizations.

It also provides guidance to those advising, informing, or assisting governing bodies. They include the following:

- *executive managers;*
- *members of groups monitoring the resources within the organization;*
- *external business or technical specialists, such as legal or accounting specialists, retail or industrial associations, or professional bodies;*
- *internal and external service providers (including consultants);*
- *auditors.*

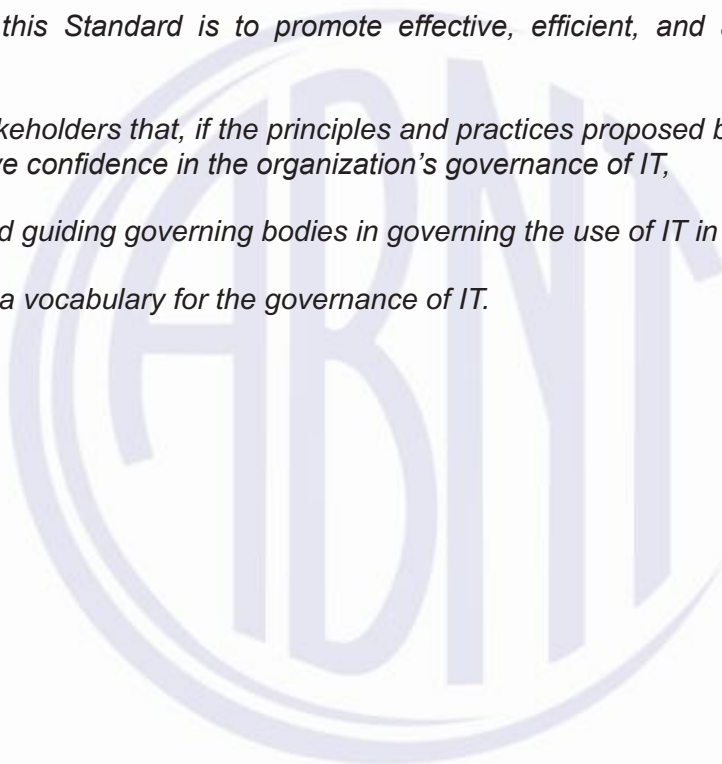
This Standard applies to the governance of the organization's current and future use of IT including management processes and decisions related to the current and future use of IT. These processes can be controlled by IT specialists within the organization, external service providers, or business units within the organization.

This Standard defines the governance of IT as a subset or domain of organizational , or in the case of a corporation, corporate governance.

This Standard is applicable to all organizations, including public and private companies, government entities, and not-for-profit organizations. This Standard is applicable to organizations of all sizes from the smallest to the largest, regardless of the extent of their use of IT.

The purpose of this Standard is to promote effective, efficient, and acceptable use of IT in all organizations by

- *assuring stakeholders that, if the principles and practices proposed by the standard are followed, they can have confidence in the organization's governance of IT,*
- *informing and guiding governing bodies in governing the use of IT in their organization, and*
- *establishing a vocabulary for the governance of IT.*



ABNT NBR ISO/IEC 38500:2018

Introdução

O objetivo desta Norma é fornecer princípios, definições e um modelo para estruturas de governança utilizarem ao avaliar, direcionar e monitorar o uso de tecnologia da informação (TI) em suas organizações.

Esta Norma é uma norma orientativa, de alto nível e com base em princípios. Além de fornecer uma ampla orientação sobre o papel de uma estrutura de governança, incentiva as organizações a usar normas apropriadas para apoiar sua governança da TI.

A maioria das organizações utiliza a TI como uma ferramenta de negócios fundamental e poucas podem funcionar efetivamente sem ela. A TI também é um fator significativo nos futuros planos de negócios de muitas organizações.

As despesas com TI podem representar uma proporção significativa das despesas de recursos financeiros e humanos de uma organização. No entanto, um retorno sobre este investimento muitas vezes não é percebido completamente e os efeitos adversos sobre as organizações podem ser significativos.

As principais razões para esses resultados negativos são a ênfase nos aspectos técnicos, financeiros e de programação das atividades de TI, em vez de enfatizar em todo o contexto de negócio do uso da TI.

Esta Norma fornece princípios, definições e um modelo para a boa governança da TI, para ajudar as pessoas no mais alto nível das organizações a entenderem e cumprirem suas obrigações legais, regulamentares e éticas em relação ao uso de TI por suas organizações.

Esta Norma está alinhada com a definição de governança corporativa que foi publicada como um Relatório do Comitê sobre os Aspectos Financeiros de Governança Corporativa (o Relatório *Cadbury*) em 1992. O Relatório *Cadbury* também forneceu a definição fundamental de governança corporativa nos Princípios de Governança Corporativa da OCDE em 1999 (revisado em 2004). A governança é distinta da gestão e, para evitar a confusão, os dois conceitos são definidos nesta Norma e elaborados no ISO/IEC TR 38502.

Esta Norma é dirigida principalmente à estrutura de governança. Em algumas organizações (tipicamente menores), os membros da estrutura de governança também podem ser gerentes executivos. Esta Norma aplica-se a todas as organizações, desde a menor até a maior, independentemente do propósito, desenho e estrutura de propriedade.

A implementação da governança de TI é coberta pela ISO/IEC TS 38501.

Tecnologia da informação — Governança da TI para a organização

1 Escopo

Esta Norma fornece princípios orientativos para os membros das estruturas de governança das organizações (que podem incluir proprietários, diretores, parceiros, gerentes executivos ou similares) sobre o uso efetivo, eficiente e aceitável de tecnologia da informação (TI) dentro de suas organizações.

Também fornece orientações para aqueles que assessoram, informam ou auxiliam as estruturas de governança. Eles incluem o seguinte:

- gerentes executivos;
- membros de grupos que monitoram os recursos dentro da organização;
- empresas externas ou especialistas técnicos, como especialistas legais ou contábeis, associações de varejo ou industriais ou associações de profissionais;
- prestadores de serviços internos e externos (incluindo consultores);
- auditores.

Esta Norma aplica-se à governança do uso atual e futuro da TI na organização, incluindo processos de gerenciamento e decisões relacionadas ao uso atual e futuro da TI. Estes processos podem ser controlados por especialistas de TI dentro da organização, prestadores de serviços externos ou unidades de negócios dentro da organização.

Esta Norma define a governança da TI como um subconjunto ou domínio da governança organizacional, ou no caso de uma corporação, governança corporativa.

Esta Norma aplica-se a todas as organizações, incluindo empresas públicas e privadas, entidades governamentais e organizações sem fins lucrativos. Esta Norma aplica-se a organizações de todos os tamanhos desde o menor até o maior, independentemente da extensão do uso da TI.

O objetivo desta Norma é promover o uso eficaz, eficiente e aceitável de TI em todas as organizações por:

- assegurar às partes interessadas que, se os princípios e práticas propostos pela norma forem seguidos, eles podem ter confiança na governança da organização em TI,
- informar e orientar as estruturas de governança no que diz respeito ao uso da TI em sua organização, e
- estabelecer um vocabulário para a governança da TI.

2 Termos e definições

Para os efeitos deste documento, aplicam-se os seguintes termos e definições.

2.1

aceitável

atende às expectativas das partes interessadas que podem ser mostradas como razoáveis ou merecidas

ABNT NBR ISO/IEC 38500:2018

2.2

responsabilizado

responsável por ações, decisões e desempenho

2.3

responsabilização

estado de ser responsabilizado

Nota 1 de entrada: A responsabilização é relacionada a uma responsabilidade alocada. A responsabilidade pode ter base em regulação ou acordo ou por meio de cessão como parte da delegação.

NOTA BRASILEIRA O termo “*accountability*” foi traduzido como “responsabilização” com o sentido de “responsabilidade por atribuições e atos”, ou seja, por prestar contas. Assim, o termo “*accountable*” é entendido como “responsabilizado”.

2.4

governança corporativa

sistema pelo qual as empresas são direcionadas e controladas

Nota 1 de entrada: Governança corporativa é a governança organizacional aplicada às corporações.

Nota 2 de entrada: De Cadbury 1992 e OCDE 1999.

Nota 3 de entrada: A definição está incluída para esclarecer a evolução na terminologia da edição anterior.

2.5

diretiva

comunica os propósitos e resultados desejados para

Nota 1 de entrada: No contexto da governança de TI, diretiva envolve a definição de objetivos, estratégias e políticas a serem adotadas pelos membros da organização para garantir que o uso da TI atenda aos objetivos de negócios.

Nota 2 de entrada: Os objetivos, as estratégias e as políticas podem ser definidos pelos gerentes se tiverem autoridade delegada pela estrutura de governança.

2.6

avaliar

considerar e fazer julgamentos informados

Nota 1 de entrada: No contexto da governança de TI, a avaliação envolve julgamentos sobre as circunstâncias internas e externas, atuais e futuras, e oportunidades relacionadas ao uso atual e futuro da TI pela organização.

2.7

gerente executivo

pessoa que tem autoridade delegada pela estrutura de governança para a implementação de estratégias e políticas para cumprir o propósito da organização

Nota 1 de entrada: Os gerentes executivos podem incluir funções que reportam à estrutura de governança ou o chefe da organização ou têm responsabilização global pela principal função de relatório, por exemplo, Diretores Executivos (CEO), Executivos de Governança, Executivos Financeiros (CFO), Executivos de Operações (COO), Executivos de Tecnologia da Informação (CIO) e papéis similares.

Nota 2 de entrada: Nas normas de gestão, os gerentes executivos podem ser designados como gerentes da Alta Direção.

2.8**governança**

sistema de direção e controle

2.9**estrutura de governança**

pessoa ou grupo de pessoas responsabilizadas pelo desempenho e conformidade da organização

2.10**governança da TI**

sistema pelo qual o uso atual e futuro de TI é dirigido e controlado

Nota 1 de entrada: Governança da TI é um componente ou um subconjunto da governança organizacional.

Nota 2 de entrada: O termo governança da TI é equivalente aos termos governança corporativa da TI, governança empresarial da TI, e governança organizacional da TI.

2.11**comportamento humano**

interação entre humanos e outros elementos do sistema

Nota 1 de entrada: O comportamento humano inclui cultura, necessidades e aspirações de pessoas como indivíduos e como grupos.

Nota 2 de entrada: Em relação à TI, existem numerosos grupos ou comunidades de seres humanos, cada um com suas próprias necessidades, aspirações e comportamentos. Por exemplo, as pessoas que usam sistemas de informação podem exibir necessidades relacionadas à acessibilidade e à ergonomia, bem como disponibilidade e desempenho. As pessoas cujos papéis do trabalho estão mudando devido ao uso de TI podem exibir necessidades relacionadas à comunicação, treinamento e tranquilidade. Pessoas envolvidas na construção e operação de recursos de TI podem exibir necessidades relacionadas a condições de trabalho e desenvolvimento de habilidades.

2.12**tecnologia da informação (TI)**

recursos utilizados para adquirir, processar, armazenar e divulgar informações

Nota 1 de entrada: Este termo também inclui “tecnologia de comunicação (TC)” e o termo composto “tecnologia de informação e comunicação (TIC)”.

2.13**investimento**

alocação de recursos para atingir objetivos definidos e outros benefícios

2.14**gerenciamento**

exercício de controle e supervisão dentro da autoridade e responsabilização estabelecidos pela governança

Nota 1 de entrada: O termo gerenciamento é frequentemente utilizado como um termo coletivo para quem é responsável pelo controle de uma organização ou partes de uma organização. O termo gerentes é usado para evitar confusão com os sistemas de gestão.

2.15**gerentes**

grupo de pessoas responsáveis pelo controle e supervisão de uma organização ou partes de uma organização

Nota 1 de entrada: Gerentes executivos são uma categoria de gerentes.

ABNT NBR ISO/IEC 38500:2018

2.16

monitorar

revisar como base para decisões e ajustes apropriados

Nota 1 de entrada: A monitoria envolve a obtenção rotineira de informações sobre o progresso em relação aos planos, bem como o exame periódico das realizações globais contra estratégias e resultados acordados para fornecer uma base para a tomada de decisões e ajustes aos planos.

Nota 2 de entrada: A monitoria inclui a revisão da *compliance* com legislação, regulamentos e políticas organizacionais relevantes.

2.17

organização

pessoa ou grupo de pessoas que tem suas próprias funções com responsabilidades, autoridades e relacionamentos para alcançar seus objetivos

Nota 1 de entrada: O conceito de organização inclui, mas não se limita a, um único negócio, companhia, corporação, firma, empreendimento, autoridade, parceria, participação, ou instituição, ou parte ou combinação, incorporada ou não, pública, ou privada.

[*Consolidated ISO Supplement 2013 – Procedures specific to ISO, Annex XL, Appendix 2*. A nota foi adicionada nesta Norma].

2.18

governança organizacional

sistema pelo qual as organizações são dirigidas e controladas

2.19

política

intenções e direção de uma organização formalmente expressada pela sua estrutura de governança ou gerentes executivos agindo com autoridade apropriada

2.20

propósito

compilação de benefícios, custos, riscos, oportunidades e outros fatores aplicáveis às decisões a serem tomadas

EXEMPLO Casos de negócios.

2.21

recursos

pessoas, procedimentos, *software*, informações, equipamentos, consumíveis, infraestrutura, capital e fundos operacionais e tempo

2.22

responsabilidade

obrigação de agir e tomar decisões para alcançar os resultados necessários

2.23

risco

efeito da incerteza nos objetivos

Nota 1 de entrada: Um efeito é um desvio em relação ao esperado – positivo e/ou negativo.

Nota 2 de entrada: Os efeitos negativos refletem ameaças, enquanto riscos positivos refletem oportunidades.

[ABNT ISO Guia 73:2009]

NOTA BRASILEIRA A definição de risco do ABNT ISO Guia 73:2009 contém cinco notas, das quais, nesta Norma, consta apenas a Nota 1 como Nota de entrada 1. A Nota de entrada 2 foi adicionada.

2.24

parte interessada

qualquer indivíduo, grupo ou organização que possa afetar, ser afetado por, ou perceber a si mesmo como afetado por uma decisão ou atividade

[ABNT ISO Guia 73:2009, adaptada]

2.25

uso da TI

planejamento, projeto, desenvolvimento, implantação, operação, gerenciamento e aplicação da TI para cumprir objetivos de negócios e criar valor para a organização

Nota 1 de entrada: O uso da TI inclui a demanda por e o fornecimento de TI.

Nota 2 de entrada: O uso da TI inclui uso atual e futuro.

3 Benefícios da boa governança da TI

A boa governança da TI ajuda os órgãos governamentais a garantir que o uso da TI contribua positivamente para o desempenho da organização, por meio de:

- inovação em serviços, mercados e negócios;
- alinhamento da TI com as necessidades da empresa;
- implementação e operação apropriadas de ativos de TI;
- clareza da responsabilidade e responsabilização pelo fornecimento e demanda de TI na consecução dos objetivos da organização;
- continuidade do negócio e sustentabilidade;
- alocação eficiente de recursos;
- boas práticas nos relacionamentos com as partes interessadas; e
- realização efetiva dos benefícios esperados de cada investimento de TI.

Esta Norma estabelece princípios para o uso efetivo, eficiente e aceitável de TI. As estruturas de governança, ao assegurarem que suas organizações sigam esses princípios, são auxiliadas na gestão de riscos e no incentivo à exploração de oportunidades decorrentes do uso da TI.

A boa governança da TI também auxilia as estruturas de governança a assegurarem a conformidade com as obrigações (regulamentares, legislativas, contratuais) quanto ao uso aceitável da TI.

ABNT NBR ISO/IEC 38500:2018

Esta Norma estabelece um modelo para a governança da TI. O risco de estruturas de governança não cumprirem suas obrigações é mitigado, por meio da devida atenção ao modelo, e a aplicação adequada dos princípios.

Sistemas de TI inadequados ou uso indevido ou inadequado de TI podem expor uma organização ao risco de não cumprir a legislação. Por exemplo, em algumas jurisdições, os membros das estruturas de governança podem ser responsabilizados pessoalmente se um sistema de contabilidade inadequado resultar em impostos que não tenham sido pagos.

Os processos que lidam com TI incorporam riscos específicos que convém que sejam abordados adequadamente. Por exemplo, as estruturas de governança e os membros das estruturas de governança podem ser responsabilizados por:

- violação de privacidade, *spam*, saúde e segurança, legislação e regulamentos de manutenção de registros;
- não *compliance* das normas relativas à segurança, responsabilidade social;
- questões relativas aos direitos de propriedade intelectual, incluindo acordos de licenciamento.

As estruturas de governança que utilizam a orientação nesta Norma são mais propensas a cumprir suas obrigações.

4 Princípios e modelo para uma boa governança da TI

4.1 Princípios

Esta Seção estabelece seis princípios para a boa governança da TI. Os princípios expressam o comportamento indicado para orientar a tomada de decisões. A declaração de cada princípio refere-se ao que convém que aconteça, mas não prescreve como, quando ou por quem os princípios seriam implementados – devido a esses aspectos dependerem da natureza da organização que implementa os princípios. Convém que as estruturas de governança requeiram que esses princípios sejam aplicados.

Princípio 1: Responsabilidade

Indivíduos e grupos dentro da organização compreendem e aceitam suas responsabilidades em relação ao fornecimento de e demanda por TI. Aqueles com responsabilidade por ações também têm autoridade para realizar essas ações.

Princípio 2: Estratégia

A estratégia de negócios da organização leva em consideração as capacidades atuais e futuras da TI; os planos para o uso da TI atendem às necessidades atuais e contínuas da estratégia de negócios da organização.

Princípio 3: Aquisição

As aquisições de TI são feitas por razões válidas, com base em constantes análises apropriadas, com uma tomada de decisão clara e transparente. Existe um equilíbrio adequado entre benefícios, oportunidades, custos e riscos, tanto no curto quanto no longo prazo.

Princípio 4: Desempenho

A TI é adequada para apoiar a organização, fornecendo os serviços, os níveis de serviço e a qualidade do serviço necessários para atender aos requisitos atuais e futuros do negócio.

Princípio 5: Conformidade

O uso da TI atende a todas as leis e regulamentos obrigatórios. Políticas e práticas são claramente definidas, implementadas e aplicadas.

Princípio 6: Comportamento Humano

As políticas, práticas e decisões de TI demonstram respeito pelo Comportamento Humano, incluindo as necessidades atuais e necessidades em evolução de todas as “pessoas no processo”.

4.2 Modelo

Convém que as estruturas de governança governem a TI por meio de três tarefas principais:

- Avaliar o uso atual e futuro de TI.
- Dirigir, preparar e implementar estratégias e políticas para garantir que o uso da TI atenda aos objetivos do negócio.
- Monitorar a conformidade com as políticas e o desempenho em relação às estratégias.

Autoridade para aspectos específicos da TI pode ser delegada aos gerentes da organização. No entanto, a responsabilização pelo uso efetivo, eficiente e aceitável da TI por uma organização permanece na estrutura de governança e não pode ser delegada.

A Figura 1 mostra o modelo de governança da TI usando *Evaluate-Direct-Monitor*. O texto a seguir na Figura 1 explica os elementos e relacionamentos descritos.

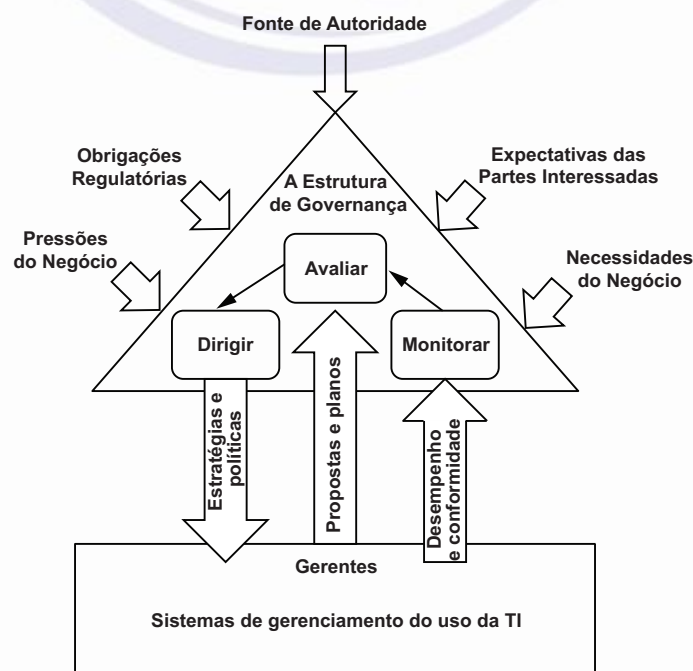


Figura 1 – Modelo para a Governança da TI

ABNT NBR ISO/IEC 38500:2018

Avaliar

Convém que as estruturas de governança examinem e façam julgamentos sobre o uso atual e futuro da TI, incluindo planos, propostas e arranjos de fornecimento (internos, externos ou ambos).

Ao avaliar o uso da TI, convém que as estruturas de governança considerem as pressões externas ou internas que atuam sobre a organização, como mudanças tecnológicas, tendências econômicas e sociais, obrigações regulatórias, expectativas legítimas das partes interessadas e influências políticas. Convém que as estruturas de governança realizem avaliação continuamente à medida em que as circunstâncias mudam. Convém que as estruturas de governança também tenham em conta as necessidades atuais e futuras das empresas – os objetivos organizacionais atuais e futuros que devem alcançar, como manter a vantagem competitiva, bem como os objetivos específicos dos planos e propostas que estão avaliando.

Dirigir

Convém que as estruturas de governança atribuam responsabilidade e dirijam a preparação e implementação de estratégias e políticas. Convém que as estratégias estabeleçam a direção dos investimentos em TI e o que convém que a TI alcance. Convém que as políticas estabeleçam comportamentos sólidos quanto ao uso da TI.

Convém que as estruturas de governança encorajem uma cultura de boa governança da TI em sua organização, requerendo que os gerentes forneçam informações oportunas, para cumprir as orientações e estarem em conformidade com os seis princípios da boa governança.

Se necessário, convém que as estruturas de governança dirijam a apresentação de propostas para aprovação para atender às necessidades identificadas.

Monitorar

Convém que as estruturas de governança monitorem, por meio de sistemas de medição apropriados, o desempenho da TI. Convém que as estruturas de governança se assegurem de que o desempenho está de acordo com as estratégias, particularmente no que se refere aos objetivos de negócios.

Convém que as estruturas de governança também garantam que a TI esteja em conformidade com as obrigações externas (regulatórias, legislativas, contratuais) e práticas internas de trabalho.

5 Orientação para a Governança da TI

5.1 Geral

As subseções a seguir fornecem orientação para os princípios gerais de boa governança da TI e as práticas requeridas para implementar os princípios.

As práticas descritas não são exaustivas, mas fornecem um ponto de partida para a discussão das responsabilidades das estruturas de governança para a governança da TI. Ou seja, as práticas descritas são orientações sugeridas para a Governança da TI.

É responsabilidade de cada organização, individualmente, identificar as ações específicas necessárias para implementar os princípios, levando em devida consideração a natureza da organização e uma análise adequada dos riscos e oportunidades referentes ao uso da TI.

5.2 Princípio 1: Responsabilidade

Avaliar

Convém que as estruturas de governança avaliem as opções de atribuição das responsabilidades em relação ao uso atual e futuro da TI pela organização. Ao avaliar as opções, convém que as estruturas de governança procurem garantir um uso efetivo, eficiente e aceitável da TI em apoio aos objetivos de negócio atuais e futuros.

Convém que as estruturas de governança avaliem a competência dos responsáveis pelas tomadas de decisões relacionadas à TI. Geralmente, convém que essas pessoas sejam gerentes de negócios que também são responsáveis pelos objetivos de negócios e desempenho da organização, auxiliados por especialistas em TI que entendem os valores e processos do negócio.

Dirigir

Convém que as estruturas de governança orientem que as estratégias sejam seguidas de acordo com as responsabilidades de TI atribuídas.

Convém que as estruturas de governança direcionem que elas recebam a informação de que elas precisam para cumprir suas responsabilidades e prestações de contas.

Monitorar

Convém que as estruturas de governança monitorem se os mecanismos apropriados de governança da TI estão estabelecidos.

As estruturas de governança devem monitorar se aqueles aos quais foram atribuídas responsabilidades reconhecem e compreendem as suas responsabilidades.

Convém que as estruturas de governança monitorem o desempenho das pessoas responsáveis pela governança da TI (por exemplo, as pessoas que participam dos comitês de direção ou de apresentação de propostas para as estruturas de governança).

5.3 Princípio 2: Estratégia

Avaliar

Convém que as estruturas de governança avaliem a evolução dos processos de TI e de negócios para garantir que a TI ofereça suporte para futuras necessidades de negócios.

Ao considerar planos e políticas, convém que as estruturas de governança avaliem o uso da TI e das atividades de TI para garantir que elas se alinhem com os objetivos da organização e atendam aos principais requisitos-chave das partes interessadas. Convém que as estruturas de governança também levem em consideração as boas práticas.

Convém que as estruturas de governança assegurem que o uso da TI seja objeto de uma gestão de riscos apropriada.

Dirigir

Convém que as estruturas de governança direcionem a preparação e o uso de estratégias e políticas que garantam que a organização se beneficie dos desenvolvimentos em TI.

ABNT NBR ISO/IEC 38500:2018

Convém que as estruturas de governança também encorajem a apresentação de propostas para utilizações inovadoras da TI que permitam à organização responder a novas oportunidades ou desafios, empreender novos negócios ou melhorar processos.

Monitorar

Convém que as estruturas de governança monitorem o progresso das propostas de TI aprovadas para garantir que elas estão alcançando objetivos nos prazos necessários usando os recursos alocados.

Convém que as estruturas de governança monitorem o uso da TI para garantir que ela esteja alcançando os benefícios pretendidos.

5.4 Princípio 3: Aquisição

Avaliar

Convém que as estruturas de governança avaliem opções para fornecer TI para realizar as propostas aprovadas, equilibrando os riscos e a relação custo-benefício dos investimentos propostos.

Dirigir

Convém que as estruturas de governança direcionem que os ativos de TI (sistemas e infraestrutura) sejam adquiridos de forma apropriada, incluindo a elaboração de documentação apropriada, assegurando que as capacidades necessárias sejam fornecidas.

Convém que as estruturas de governança direcionem que os arranjos de fornecimento (incluindo os arranjos internos e externos de abastecimento) atendam às necessidades de negócios da organização.

Convém que as estruturas de governança direcionem que sua organização e fornecedores desenvolvam uma compreensão compartilhada da intenção da organização em fazer uma aquisição de TI.

Monitorar

Convém que as estruturas de governança monitorem os investimentos em TI para garantir que eles forneçam as capacidades necessárias.

Convém que as estruturas de governança monitorem até que ponto a organização e os fornecedores mantêm a compreensão compartilhada da intenção da organização em fazer qualquer aquisição de TI.

5.5 Princípio 4: Desempenho

Avaliar

Convém que as estruturas de governança avaliem os planos propostos pelos gerentes para garantir que a TI apoie processos de negócios com a capacitação e capacidade necessárias. Convém que estas propostas abordem a continuidade do funcionamento normal da organização e o tratamento dos riscos associados ao uso da TI.

Convém que as estruturas de governança avaliem os riscos para a continuidade do funcionamento dos negócios decorrentes das atividades da TI.

Convém que as estruturas de governança avaliem os riscos para a integridade da informação e a proteção dos ativos de TI, incluindo a propriedade intelectual associada e a memória organizacional.

Convém que as estruturas de governança avaliem opções para assegurar que decisões efetivas e oportunas sobre o uso da TI apoiem os objetivos do negócio.

Convém que as estruturas de governança avaliem regularmente a eficácia e o desempenho da governança da TI da organização.

Dirigir

Convém que as estruturas de governança assegurem a alocação de recursos suficientes para que a TI atenda às necessidades da organização, de acordo com as prioridades e restrições orçamentárias acordadas.

Convém que as estruturas de governança dirijam os responsáveis para garantir que a TI suporte a organização, quando requerida por razões do negócio, com dados corretos e atualizados, que são protegidos contra perda ou uso indevido.

Monitorar

Convém que as estruturas de governança monitorem até que ponto a TI apoia o negócio. Convém que as estruturas de governança monitorem até que ponto os recursos alocados e os orçamentos são priorizados de acordo com os objetivos do negócio.

Convém que as estruturas de governança monitorem até que ponto as políticas, como as referentes à acurácia dos dados e ao uso eficiente das TI, são seguidas adequadamente.

5.6 Princípio 5: Conformidade

Avaliar

Convém que as estruturas de governança avaliem regularmente até que ponto a TI atende às obrigações (regulamentares, legislativas, contratuais), políticas internas, normas e diretrizes profissionais.

Convém que as estruturas de governança avaliem regularmente a conformidade interna da organização com o seu quadro de referência (*framework*) de governança da TI.

Dirigir

Convém que as estruturas de governança dirijam os responsáveis para estabelecer mecanismos regulares e rotineiros para garantir que o uso da TI atenda às obrigações, políticas internas, normas e diretrizes relevantes.

Convém que as estruturas de governança direcionem que as políticas sejam estabelecidas e executadas para permitir que a organização atenda as suas obrigações internas no seu uso da TI.

Convém que as estruturas de governança direcionem que a equipe de TI siga as diretrizes relevantes para o comportamento e desenvolvimento profissional.

Convém que as estruturas de governança direcionem que todas as ações relacionadas à TI sejam éticas.

Monitorar

Convém que as estruturas de governança monitorem a conformidade da TI por meio de relatórios adequados e práticas de auditoria, garantindo que as revisões sejam oportunas, abrangentes e adequadas para a avaliação da extensão da satisfação da organização.

ABNT NBR ISO/IEC 38500:2018

Convém que as estruturas de governança monitorem as atividades da TI, incluindo a eliminação de ativos e dados, para garantir que o meio ambiente, a privacidade, o gerenciamento estratégico do conhecimento, a preservação da memória organizacional e outras obrigações relevantes sejam atendidas.

5.7 Princípio 6: Comportamento Humano

Avaliar

Convém que as estruturas de governança avaliem as atividades da TI para garantir que os comportamentos humanos sejam identificados e adequadamente considerados.

Dirigir

Convém que as estruturas de governança direcionem que as atividades de TI são consistentes com o comportamento humano identificado.

Convém que as estruturas de governança direcionem que riscos, oportunidades, problemas e preocupações possam ser identificados e relatados por qualquer pessoa a qualquer momento. Convém que estes riscos sejam gerenciados de acordo com políticas e procedimentos publicados e escalados para os decisores relevantes.

Monitorar

Convém que as estruturas de governança monitorem as atividades de TI para garantir que os comportamentos humanos identificados permaneçam relevantes e que lhes seja dada a atenção adequada.

Convém que as estruturas de governança monitorem as práticas de trabalho para garantir que sejam consistentes com o uso adequado da TI.

Bibliografia

- [1] ISO/IEC TR 38502, *Information technology – Governance of IT – Framework and model*
- [2] ISO/IEC TS 38501, *Information technology – Corporate governance of IT implementation guide*
- [3] *ISO/IEC Directives Part 1, Consolidated ISO Supplement, 2013, Annex SL, Appendix 2*
- [4] Report of the Committee on the Financial Aspects of Corporate Governance. Sir Adrian Cadbury, London, 1992 ISBN 0 85258 913 1
- [5] OECD Principles of Corporate Governance, OECD, 1999 and 2004

